INFORME TÉCNICO DE LABORATORIO

INSTITUTO TECNOLÓGICO DE LAS AMÉRICAS

Las Americas Institute of Technology

Hardening basado en CIS Benchmark en GNS3

Auditoría automatizada, aplicación de controles y verificación posterior



Topología lógica del laboratorio: NAT1, R1, SW y Kali Auditor.

ESTUDIANTE	DATOS DEL LABORATORIO
José Miguel Díaz Ferreras	Matrícula: 2025-0693
Asignatura / área	Seguridad de Redes
Fecha de la práctica	10/11/2026
Plataformas	GNS3, Cisco IOS 15.2, Kali Linux, Python 3.13, Netmiko 4.8.0

1. Resumen ejecutivo

Se implementó una red de laboratorio en GNS3 compuesta por un router Cisco R1, un switch IOSvL2 SW y una máquina Kali Linux. Desde Kali se desarrolló y ejecutó una herramienta Python con Netmiko que evalúa siete controles administrativos por equipo, genera informes JSON sin modificar la configuración y puede aplicar cambios seleccionados tras una confirmación explícita.

La auditoría inicial identificó 8 controles conformes de un total de 14. Tras aplicar las correcciones y ejecutar una auditoría independiente, los 14 controles seleccionados resultaron conformes. Las pruebas ICMP posteriores confirmaron cinco respuestas de cinco hacia cada dispositivo. El estudiante guardó posteriormente las configuraciones activas de ambos equipos.

Indicador	Situación inicial	Resultado final
R1	5/7 controles	7/7 controles
SW	3/7 controles	7/7 controles
Total	8/14 controles	14/14 controles
Conectividad desde Kali	5/5 por equipo antes de los cambios	5/5 por equipo tras los cambios
Informes	JSON de solo lectura	JSON de aplicación y auditoría final

2. Propósito y alcance

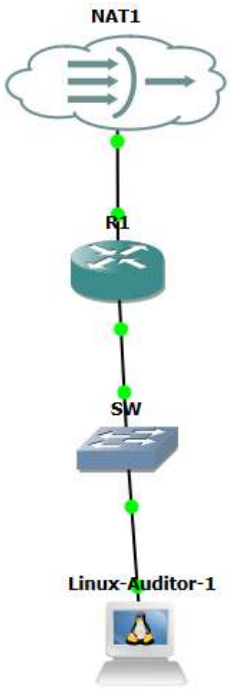
- Diseñar una topología funcional con router, switch y un sistema auditor Linux.
- Comprobar controles administrativos inspirados en guías CIS para dispositivos Cisco IOS.
- Automatizar los modos de auditoría sin cambios y de aplicación con verificación posterior.
- Documentar los comandos, las razones de cada cambio, las evidencias y los running-configs finales saneados.

Nota de alcance: las 14 comprobaciones son una selección académica; no representan una certificación CIS ni una evaluación exhaustiva de todas las recomendaciones del benchmark.

3. Requisitos de entrega y evidencias

El repositorio mantiene cinco elementos principales: README.md, configs/, docs/, images/ y scripts/. La versión del video demostrativo de esta práctica sigue pendiente de incorporar a la primera sección del README.

4. Arquitectura de red y direccionamiento



Captura real de la topología en GNS3.

Nodo	Interfaz / dirección	Función
NAT1	192.168.42.1 (gateway externo)	Conectividad externa de la simulación
R1	Fa0/0: 10.6.94.1/24	Gateway de la LAN, NAT inside
R1	Gi1/0: 192.168.42.212/24, DHCP	Uplink, NAT outside
SW	VLAN 1: 10.6.94.2/24	Administración del switch
Kali Linux	eth0: 10.6.94.10/24	Auditoría y ejecución del script

R1 realiza NAT/PAT para permitir la salida de Kali. El switch y el router responden a pruebas de conectividad local. La automatización usa SSH y credenciales introducidas de forma interactiva; no se incorporan contraseñas en el código.

5. Software utilizado

Router R1: Cisco 7206VXR, IOS 15.2(4)S6. Switch SW: Cisco IOSvL2, IOS experimental 15.2 compilado en 2020. Kali Linux en nodo QEMU de GNS3; Python 3.13.12; Netmiko 4.8.0 y Paramiko 3.5.1 en entorno virtual.

6. Metodología de auditoría



Flujo general: revisión de estado → autorización → aplicación → verificación.

6.1 Preparación y línea base

Se habilitó SSHv2 en R1 y SW con claves RSA y autenticación local antes de ejecutar la primera auditoría automatizada. Este paso fue necesario para que Netmiko accediera a los dispositivos. Por ello, el informe inicial de 8/14 corresponde a la configuración posterior a la preparación SSH, no a una configuración de fábrica.

6.2 Modo auditar (solo lectura)

Comando ejecutado en Kali:

```
python cis_hardening.py auditar
```

El programa consulta show running-config y show ip ssh, evalúa siete reglas por equipo y guarda un JSON con sus resultados sin enviar comandos de configuración.

6.3 Modo aplicar (cambios autorizados)

```
python cis_hardening.py aplicar
```

Antes de modificar dispositivos, solicita escribir exactamente APLICAR. Solo corrige controles pendientes de HTTP, HTTPS y tiempo de inactividad en consola/VTY. El script vuelve a consultar el estado y genera un informe posterior. No guarda automáticamente en NVRAM; el guardado final se realizó manualmente después de las pruebas.

6.4 Registros originales

La evidencia se conserva en tres archivos sin alterar: auditar_20261110_202713.json (línea base), aplicar_20261110_203828.json (aplicación y verificación) y auditar_20261110_204226.json (auditoría final independiente). Se omitió de la entrega el intento preliminar con fallo de autenticación.

7. Controles seleccionados y justificación

ID interno	Control	Justificación / configuración
HTTP-01	Administración HTTP deshabilitada	no ip http server; reduce la exposición de un servicio innecesario.
HTTPS-02	Administración HTTPS deshabilitada si no se utiliza	no ip http secure-server; decisión específica del laboratorio. HTTPS no es inseguro por naturaleza.
CON-03	Consola con timeout de 5 minutos	line con 0 + exec-timeout 5 0; limita sesiones locales abandonadas.
VTY-04	Sesión remota con timeout de 5 minutos	line vty 0 4 + exec-timeout 5 0; reduce el tiempo de exposición de sesiones inactivas.
SSH-05	SSHv2 activo	ip ssh version 2; habilitado antes del primer escaneo para preparar automatización.
VTY-06	VTY solo por SSH	transport input ssh; evita administrar por Telnet.
AUTH-07	Autenticación local de VTY	login local; utiliza usuarios locales configurados en el equipo.

7.1 Cambios ejecutados por el modo aplicar

Equipo	Cambios efectivamente aplicados
R1	Timeout de consola y timeout VTY, ambos a 5 minutos.
SW	Deshabilitar HTTP y HTTPS administrativos; timeout de consola y timeout VTY a 5 minutos.

Los comandos de SSH y usuario local ya estaban presentes en ambos dispositivos en el momento de la auditoría inicial; el modo de aplicación no volvió a generarlos.

8. Evidencia de auditoría y remediación



Auditoría inicial: R1 5/7, SW 3/7; 8/14 controles conformes.



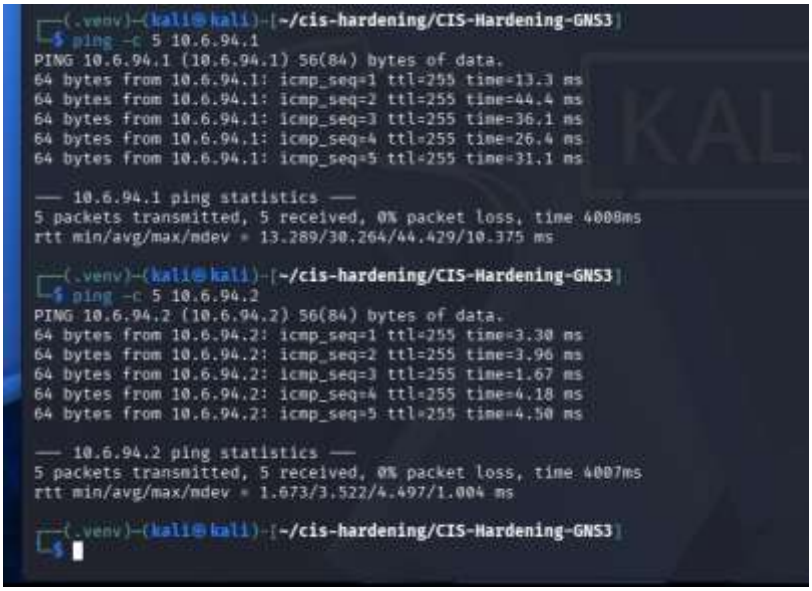
Modo aplicar: cambios de HTTP/HTTPS y timeout en el switch con verificación posterior.

9. Validación posterior del laboratorio

Control / prueba	R1 (antes → después)	SW (antes → después)
HTTP deshabilitado	Cumple → Cumple	No cumple → Cumple
HTTPS deshabilitado	Cumple → Cumple	No cumple → Cumple
Timeout consola	No cumple → Cumple	No cumple → Cumple
Timeout VTY	No cumple → Cumple	No cumple → Cumple
SSHv2	Cumple → Cumple	Cumple → Cumple
VTY solo SSH	Cumple → Cumple	Cumple → Cumple
Autenticación VTY local	Cumple → Cumple	Cumple → Cumple



Auditoría final independiente: 14 controles conformes sobre los 14 definidos.



Kali a R1 y SW: cinco respuestas de cinco, 0 % de pérdida tras el hardening.

10. Configuraciones finales y protección de credenciales

El estudiante confirmó el guardado manual mediante copy running-config startup-config en ambos dispositivos, tras la auditoría posterior y las pruebas de conectividad. Los archivos finales presentes en configs/ fueron elaborados a partir de los show running-config reales recibidos en la conversación.

Dispositivo	Cambios comprobados en running-config final
R1	ip ssh version 2; no ip http server; no ip http secure-server; exec-timeout 5 0 en consola y VTY; login local; transport input ssh.
SW	ip ssh version 2; no ip http server; no ip http secure-server; exec-timeout 5 0 en consola y VTY; login local; transport input ssh.

10.1 Redacción de información sensible

Las copias publicables se denominan configs/R1_running-config_final_sanitizado.txt y configs/SW_running-config_final_sanitizado.txt. Los hashes asociados al usuario auditor se sustituyeron por marcadores. En SW se omitieron los textos de licencia repetidos que la imagen IOSv inserta en banners. Por estas omisiones, son evidencias documentales y no archivos de restauración directa.

10.2 Riesgos y límites pendientes

- IOS 15.2 y la imagen IOSv experimental necesitan revisión de compatibilidad y mantenimiento; se usaron algoritmos SSH heredados para las pruebas.
- La comunidad CIS mantiene versiones de Cisco IOS más recientes; este trabajo no atribuye números de recomendación específicos sin verificar la edición histórica correspondiente.
- no aaa new-model permanece configurado; el laboratorio usa usuarios locales y no evalúa una solución AAA completa.
- El switch aún muestra no service password-encryption; esta comprobación no forma parte del conjunto de siete controles auditados.
- R1 mantiene exec-timeout 0 0 en la línea auxiliar; el script solo evalúa consola y VTY.
- El conjunto de siete controles no evalúa restricciones de origen SSH mediante ACL, registros centralizados, NTP ni todas las configuraciones de capa 2.

Los hashes tipo 5 se retiraron del material público. Como fueron compartidos durante el laboratorio, resulta prudente rotar las contraseñas administrativas antes de publicar el repositorio.

12. Conclusiones

El laboratorio cumplió el objetivo académico de automatizar una revisión inicial sin cambios, aplicar un conjunto controlado de recomendaciones de hardening y verificar los resultados mediante una nueva auditoría. Los resultados comprobados evolucionaron de 8/14 a 14/14 controles seleccionados, sin interrupción observable de la conectividad ICMP entre Kali y los dispositivos.

La metodología resulta reproducible dentro del entorno GNS3 y deja trazabilidad mediante script, capturas, informes JSON y configuraciones finales saneadas. Una adopción real requeriría una guía CIS de edición específica para la plataforma, revisión de todos los controles aplicables, mecanismos modernos de autenticación y una política de cambios y respaldos.